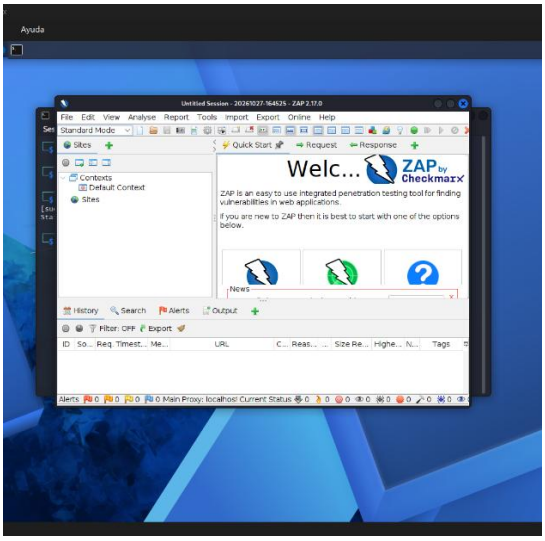
WEB SECURITY CHALLENGE

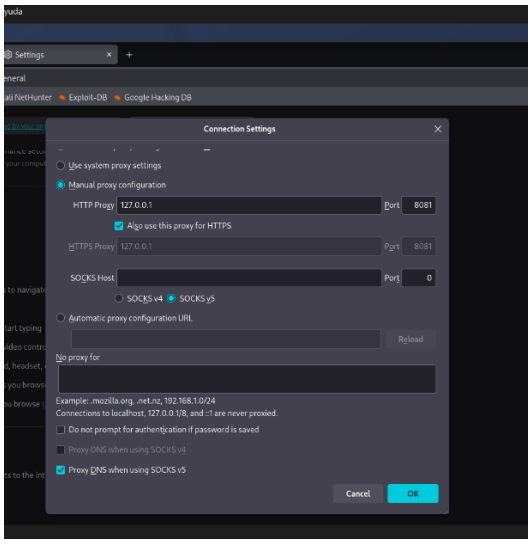
Vanessa Valderrama

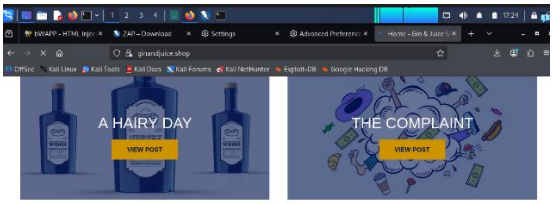
Hacker Women Council

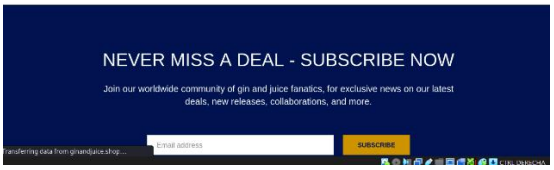
---

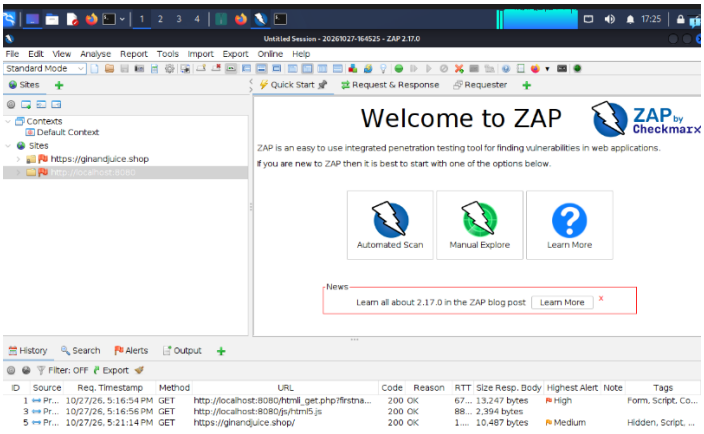
1. **Preparación de entorno.**
   - ➢ Abrir terminal
   - ➢ Configurar navegador
   - ➢ Ingreso a https://ginandjuice.shop/
   - ➢ Verificación de tráfico en ZAP





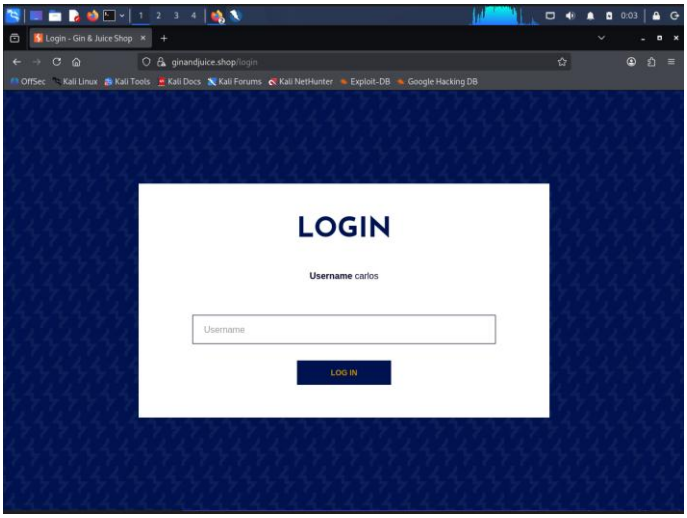






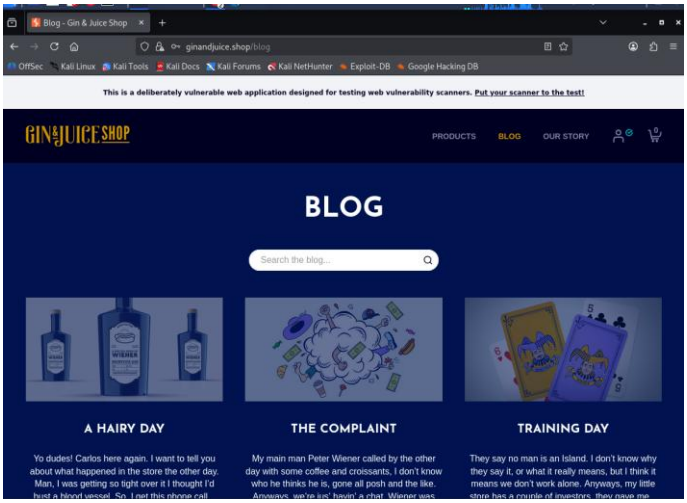
2. **Exploración.**
   - ➢ Login

ID	Sour...	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. B...	Highest Al...	N...	Tags
1	⇔ Pr...	10/27/26, 11:25:06 ...	GET	https://ginandjuice.shop/login	200	OK	1...	7,493 bytes	Medium		AntiCSRF, For...



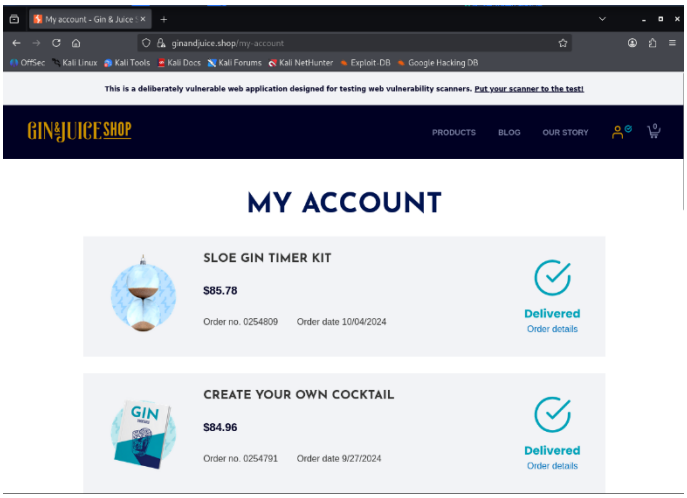
- Blog

ID	Sour...	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. B...	Highest Al...	N...	Tags
151	⇔ Pr...	10/27/26, 11:33:41 ...	GET	https://ginandjuice.shop/blog	200	OK	7...	11,053 bytes	Informa...		Form, Hidden, ...



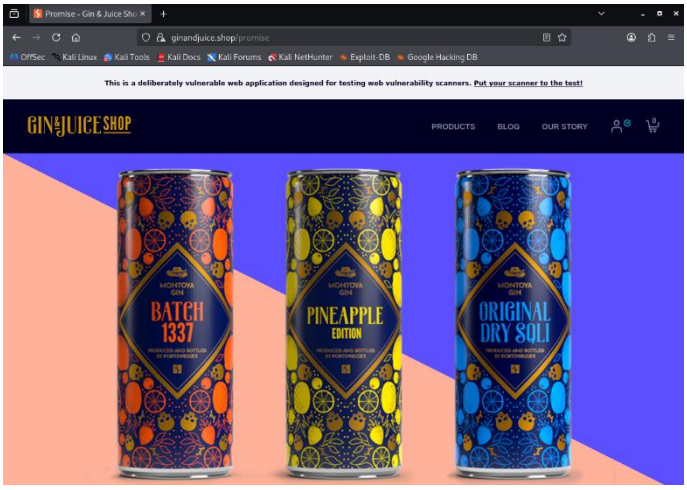
- My account

ID	Sour...	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. B...	Highest Al...	N...	Tags
145	⇔ Pr...	10/27/26, 11:31:26 ...	GET	https://ginandjuice.shop/my-account	200	OK	2...	13,317 bytes			Hidden, Script,...



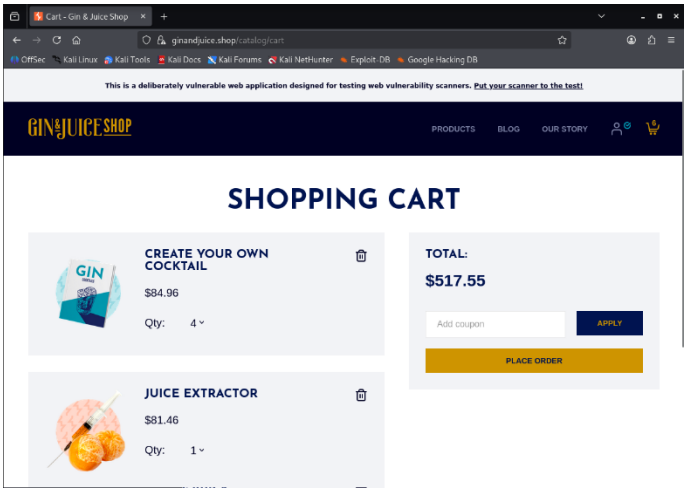
- Our promise

ID	Sour...	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. B...	Highest Al...	N...	Tags
51	Pr...	10/27/26, 11:26:50 ...	GET	https://ginandjuice.shop/promise	200	OK	1...	8,140 bytes	Medium		Hidden, Script,...



- Shopping cart

ID	Sour...	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. B...	Highest Al...	N...	Tags
138	Pr...	10/27/26, 11:31:05 ...	GET	https://ginandjuice.shop/catalog/cart	200	OK	1...	43,326 bytes	Medium		AntiCSRF, For...



3. Documentación de hallazgos.

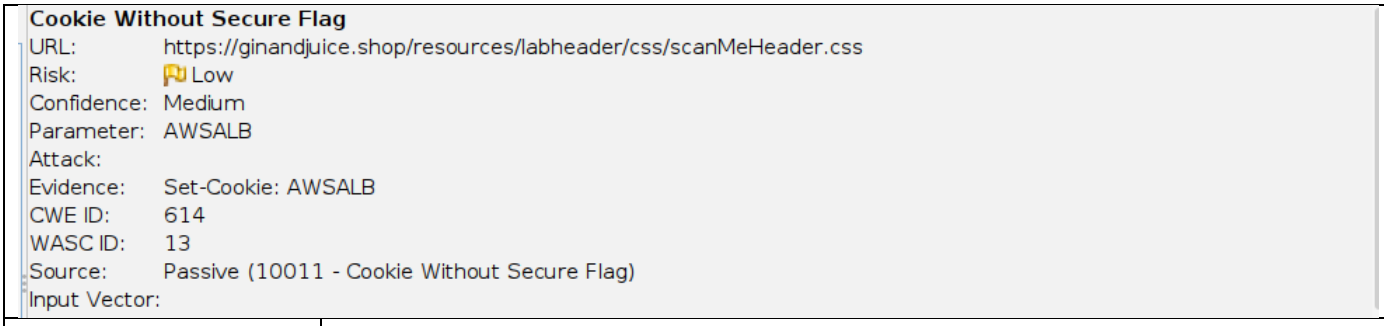
Vulnerable JS Library URL: https://ginandjuice.shop/resources/js/angular_1-7-7.js Risk: High Confidence: Medium Parameter: Attack: Evidence: /* AngularJS v1.7.7 CWE ID: 1395 WASC ID: Source: Passive (10003 - Vulnerable JS Library (Powered by Retire.js)) Input Vector:

Nombre de la alerta	Vulnerable jS Library
Nivel de riesgo	Alto
URL o componente	http://ginandjuice.shop/resources/js/angular_1-7-7.js
Parámetro afectado	
Evidencia	/* AngularjS v1.7.7
Descripción técnica	La biblioteca identificada parece ser vulnerable.
Impacto potencial	Un atacante puede explotar vulnerabilidades conocidas para ejecutar código malicioso en el navegador de las víctimas.
Recomendación	Actualice a la última versión de la biblioteca afectada.

Absence of Anti-CSRF Tokens URL: https://ginandjuice.shop/catalog/product?productId=8 Risk: Medium Confidence: Low Parameter: Attack: Evidence: <form id="stockCheckForm" action="/catalog/product/stock" method="POST"> CWE ID: 352 WASC ID: 9 Source: Passive (10202 - Absence of Anti-CSRF Tokens) Input Vector:

Nombre de la alerta	Absence of Anti-CSF Tokens
Nivel de riesgo	Medio
URL o componente	https://ginandjuice.shop/catalog/product?productid=8
Parámetro afectado	

Evidencia	<form id=”stockCheckForm” action=”/catalog/product/stock” method=”POST”>
Descripción técnica	No se encontraron tokens Anti-CSRF en un formulario de envío HTML. La falsificación de petición en sitios cruzados (CSRF) es un ataque que consiste en obligar a una víctima a enviar una solicitud HTTP a un destino determinado sin su conocimiento o intención, con el fin de realizar una acción en nombre de la víctima. La causa subyacente es que la funcionalidad de la aplicación utiliza...
Impacto potencial	Un atacante puede forzar a un usuario autenticado a enviar solicitudes no deseadas usando su propia sesión.
Recomendación	Utilice una biblioteca o marco de trabajo verificado que no permita que ocurra esta debilidad o que proporcione construcciones que faciliten evitar esta debilidad.



Nombre de la alerta	Cookie Without Secure Flag
Nivel de riesgo	Bajo
URL o componente	https://ginandjuice.shop/resources/labheader/css/scsnMeHeader.css
Parámetro afectado	AWSALB
Evidencia	Set-Cookie: AWSALB
Descripción técnica	Se ha establecido una cookie sin el atributo de seguridad (secure flag), lo que significa que se puede acceder a la cookie a través de conexiones no cifradas
Impacto potencial	Un atacante en la misma red podría realizar un ataque de intermediario o sniffing de tráfico para interceptar la cookie en texto plano cuando viaje sobre HTTP no cifrado.
Recomendación	Siempre que una cookie contenga información confidencial o sea un token de sesión, debe transmitirse utilizando un canal cifrado. Asegúrese de que el atributo de seguridad (secure flag) esté configurado para las cookies que contengan dicha información sensible.

4. Conclusiones.

Durante este laboratorio aprendí a interceptar y analizar el tráfico de red mediante OWASP ZAP configurado como proxy intermediario en el navegador. La herramienta recopiló detalles de peticiones y respuestas HTTP/HTTPS, permitiéndome identificar desde librerías desactualizadas con fallos conocidos de riesgo alto (como AngularJS v1.7.7) hasta fallas de configuración de riesgo medio y bajo, entre las cuales destacan la ausencia de tokens Anti-CSRF en formularios de envío y la falta del atributo Secure Flag en las cookies de sesión. Esta inspección pasiva me ayudó a comprender cómo se detectan de manera sistemática los vectores de ataque en una aplicación web. En una evaluación dentro de un entorno real, inspeccionaría las mecánicas de gestión de sesiones, la lógica de negocio en el proceso de compra, la

validación de roles de usuario y las políticas de seguridad en los encabezados HTTP para asegurar un diagnóstico integral de la plataforma.

El aspecto más retador de este proceso fue la fase previa de preparación y despliegue del entorno práctico, en especial la instalación y ejecución de bWAPP, ya que me enfrenté a diversos inconvenientes con la configuración de dependencias y el manejo de comandos en la consola. Logré resolver estas dificultades investigando la sintaxis adecuada, ajustando los parámetros de red y siguiendo paso a paso la verificación del flujo de tráfico entre el proxy de ZAP y el navegador. Aunque requirió un esfuerzo considerable superar estos obstáculos técnicos, la experiencia me permitió familiarizarme con el comportamiento de los servicios en línea de comandos. Al estar dando mis primeros pasos en el área de ciberseguridad, reconozco que aún necesito profundizar mis conocimientos teóricos y prácticos para interpretar con mayor soltura las alertas, los encabezados y las estructuras de peticiones HTTP. El volumen de información que genera un escáner de seguridad puede resultar abrumador al inicio, por lo que comprender la diferencia entre cada tipo de riesgo exige un estudio continuo de los estándares de la industria, así como un entrenamiento progresivo en el uso de herramientas de auditoría.